

Rating matrices and treatment options

This morning's lecture set out the process and its vocabulary. It left one question open, the one management will ask as soon as risks are presented to it: what does the CISO rely on to say that this risk is more serious than that one, and why does this one deserve a budget while that one waits? This tutorial answers by building the instrument that carries that answer, the rating matrix, then by using it to decide. By the end of the session, the scenarios built in session 6 will all have a place on a grid, a decision and an owner.

Session objectives

By the end of this tutorial:

- **Explain** what a rating matrix is, what it calculates and what it does not calculate
- **Rate** a risk scenario for severity and likelihood on the scales the group justified in session 5, without redefining them
- **Place** an acceptance line and say which body has the legitimacy to set it
- **Choose** a treatment option for each risk and defend that choice before a challenger
- **Spot** the three classic manipulations by which a rating becomes an exercise in justification

Prerequisites

- The severity scales G1 to G4 and likelihood scales V1 to V4 written and justified in session 5, in the D5 file. **They are reused as they are.** Re-rating with a fresh scale would make the risks already treated incomparable, and that is exactly what an auditor will go and check.
- The strategic and operational scenarios built in session 6, in particular those going through the critical stakeholders of the subsidiary under review (§3 and §6 of the subsidiary pack).
- The vocabulary from this morning's lecture: risk assessment, evaluation, treatment, residual risk, register.

What to know before the exercise

A quarter of an hour of framing, on two notions the lecture named without equipping them.

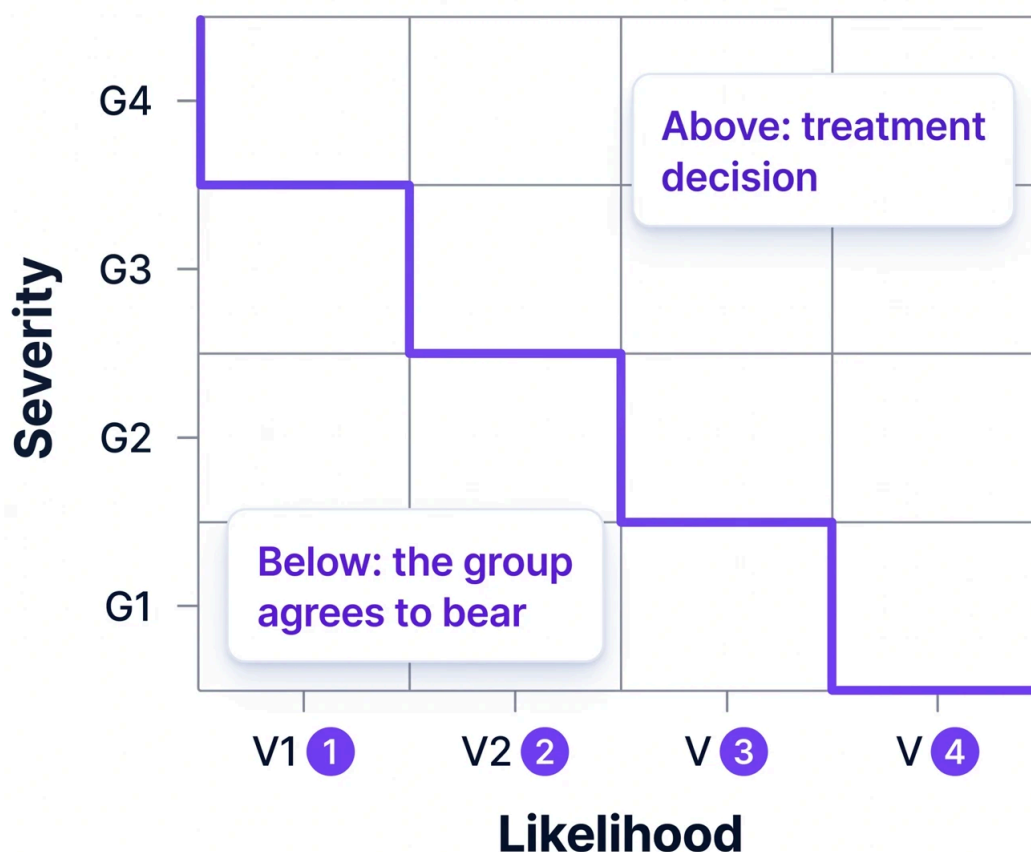
The rating matrix, first. The problem it deals with is a problem of agreement, not of calculation: when five people examine the same scenario, they produce five judgments, and nothing allows them to be added up. A **rating matrix** is a two-axis grid, severity on one side, likelihood on the other, each cell of which carries a risk level agreed

in advance. Its mechanics come in three steps: the scenario is rated on each axis separately, the cell at the intersection is read, and the level found there becomes the risk's position in the portfolio. The point is not precision, it lies elsewhere: the matrix forces the separation of two questions that discussion always mixes, "how serious would it be" and "how likely is it". Most disagreements in workshops come from two people answering different questions while believing they contradict each other.

What the matrix does not do deserves to be said just as plainly. It calculates nothing; it applies a convention someone wrote, and two organizations can place the same scenario at two different levels without either being wrong. It does not replace judgment, it records it and makes it debatable. And it never says what to do: it says where the risk stands, the decision remains entirely open.

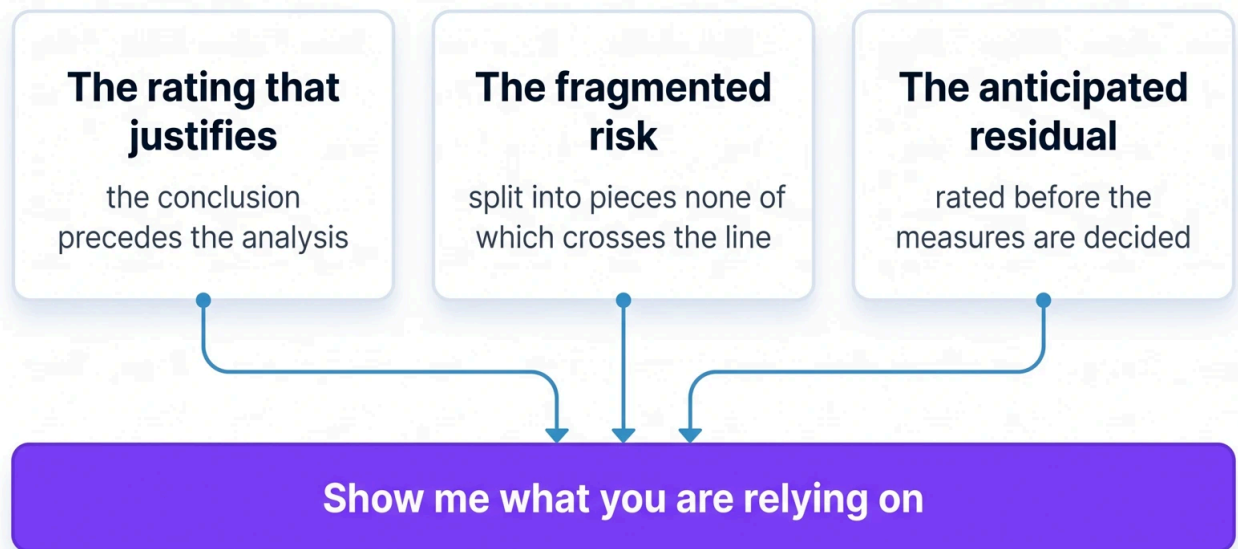
The group's tool offers two grids, and the choice between them is already a methodological decision. The "4x4 EBIOS-RM" matrix crosses four levels of consequence and four of likelihood; the "5x5 ISO-27005" matrix offers five of each. The even number has a virtue the odd number does not: it offers no middle. On a five-level scale, an undecided workshop systematically rates in the center, and the portfolio ends up with all its risks in the same place, which no longer ranks anything. The MERIDIAN group works in 4x4, consistent with the four-level scales justified in session 5.

The acceptance line, next, and it is the most political notion of the day. The problem: once the risks are rated, nothing yet says which ones are tolerable. An **acceptance line** is the boundary, drawn on the matrix, separating the levels the organization agrees to carry from those it refuses. Its mechanics are simple, its consequences are not: every risk above the line calls for a treatment decision, every risk below it can stay as it is, and moving the line by one cell moves the year's security budget.

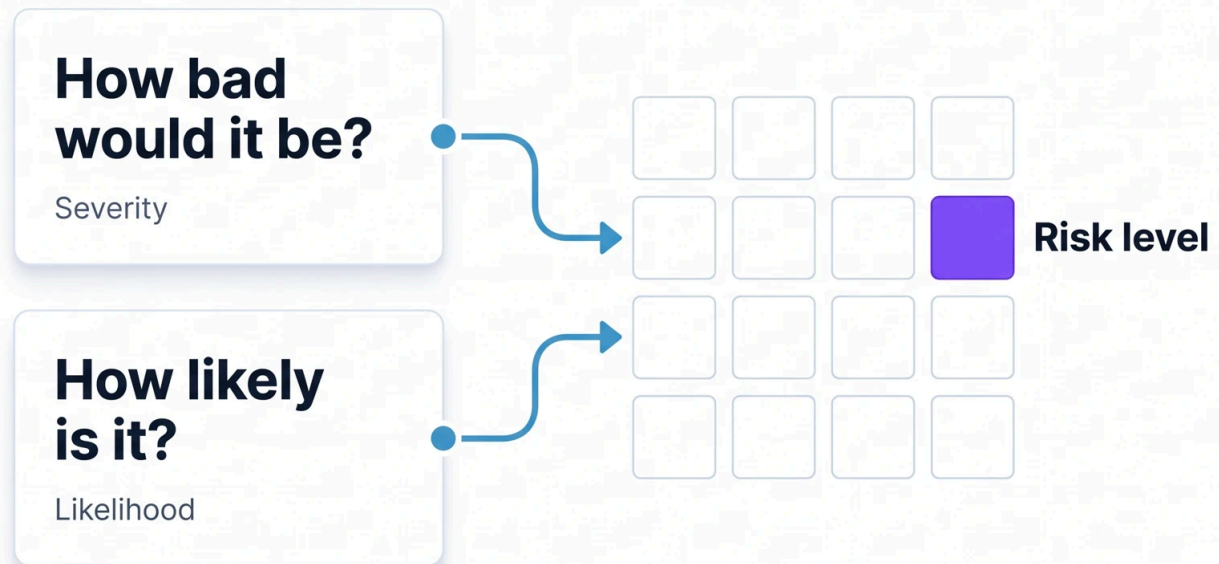


Remember who draws it, because that is the heart of the governance seen in session 1. The acceptance line translates risk appetite, and appetite does not belong to the CISO. A CISO who sets the line alone takes the place of management, and on the day of the incident will carry alone a decision they had no legitimacy to make. The CISO's role is to prepare, to inform, to propose, and to obtain a written decision. The guide's acceptance classes, recalled this morning, provide the vocabulary of that decision: acceptable as is, tolerable under control, unacceptable.

A final word on the **three manipulations** to know how to recognize, because they will be attempted. The first consists of rating likelihood downward because the treatment would be expensive: the conclusion precedes the analysis, and the rating becomes a justification. The second consists of splitting one big risk into several small ones, none of which crosses the line: the risk has not decreased, it has been fragmented. The third consists of rating the residual risk before the measures have been decided, which amounts to measuring the effect of a treatment that does not yet exist. All three are spotted by asking one thing: show me what this rating rests on.



Exercise 1: rating four of the group's scenarios (15 minutes)



Scenario

The Group CISO (RSSI Groupe) is preparing the group's security committee. Four scenarios from the workshops must be presented there already rated, and the Chief Executive Officer has warned that she wants not a table of colors, but one sentence of justification per rating. The four scenarios are the group's; the one concerning the subsidiary under review will be found in the register this afternoon.

#	Risk scenario	What the workshops have established
A	A profit-driven attacker hits the availability of care data by going through the HIS vendor's shared remote maintenance identifier	Shared privileged account, with no individual traceability; the Santé subsidiary carries care activities
B	An attacker compromises the workstation of an administrator of the Éducation & Territoires cluster and accesses the administrative data of Territoires	Identity directory common to the cluster, administration accounts shared between the two teams, personal data of service users; the project to connect to Territoires' databases is refused, not deployed
C	A booby-trapped update applied by the WMS TPAM provider brings malicious code into Logistique	Comparable to the NotPetya pattern through a third party's update; the TPAM provider applies its own at night, without validation; software supply chain
D	An internal staff member mistakenly exfiltrates a personal data file to an unapproved online service	No policy on the use of external services; limited volume, one subsidiary

Instructions

Rate the four scenarios in the table on both axes, severity then likelihood, with the D5 scales G1 to G4 and V1 to V4 as they stand, then read their level on the 4x4 matrix. Each rating holds in one sentence that refers to a named level of the scale and to a signal: a deviation found in the audit, an observed practice, a comparable public incident. The word "significant" without a reference to the scale is worth nothing. For the scenario that caused the most hesitation, say what would change the rating; that is the question the committee will ask.

To produce: the four scenarios rated on both axes, their level read on the matrix, one sentence of justification per rating, and two lines on the most debated scenario.

Working method

Rate severity before likelihood, systematically, and without looking at the other axis. This is workshop discipline, not affectation: severity is judged on the harm to the mission, and knowing a scenario is likely imperceptibly pushes toward finding it more serious.

✓ Exercise 2: the acceptance line, and who draws it (10 minutes)

Scenario

The Group CISO presents the matrix to the committee. The Director of Logistics proposes placing the acceptance line so that scenario C falls just below it: "these are updates from our long-standing maintenance provider, we are not going to block production over that". The Chief Executive Officer asks for the CISO's opinion before deciding.

Instructions

The Chief Executive Officer expects the Group CISO's opinion before deciding. Say where to place the acceptance line and on what basis, relying on the guide's acceptance classes recalled this morning rather than on intuition. Then answer the committee in three sentences: what the line proposed by Logistics would concretely imply, what the CISO recommends, and what the CISO asks for in writing. Finally name who signs this decision at MERIDIAN, using the division of roles from session 1, and say why it is not the CISO.

To produce: the position of the line and its basis, the reply to the committee in three sentences, and the body that signs, with the reason.

What the exercise tests

The ability to defend a position without confiscating the decision. The two symmetrical errors are yielding in silence, which manufactures an acceptance nobody has signed, and deciding in management's place, which puts the CISO in an untenable position.

✓ Exercise 3: choosing and defending a treatment option (20 minutes)

Scenario

The four scenarios are rated and the line is settled. For each risk above it, a decision, an owner and a deadline are needed. The Chief Financial Officer will attend the meeting and ask the same question on every line: how much, and why now.

Instructions

For each of the four scenarios, settle one option among reduce, accept, avoid, transfer, justified in one sentence; at least one of the four is not "reduce", otherwise the other families were not examined. Each reduction carries its measure, its named owner and its deadline: a measure without an owner is a wish. For scenario A, say what the proposed cyber insurance would really cover and what it does not. For scenario D, write the acceptance in due form: the level that signs it, what it contains, the deadline of its re-examination.

To produce: four justified decisions, the reduction measures with owner and deadline, the real coverage of the insurance on A, and the formal acceptance of D.

Working method

Phrase each decision as it will be read by a third party in two years, without its author in the room to explain it. The test: does the sentence say who decided, what, why and until when?



Answer keys and assessment criteria – cliquer pour révéler